

AI - PROCUREMENT

Tue, 18 Aug 2026 16:48:57 IST

TABLE OF CONTENTS

Vulnerabilities by Plugin

- 112543 (1) - HTTPS Not Detected
- 98060 (5) - Missing 'X-Frame-Options' Header
- 112529 (5) - Missing 'X-Content-Type-Options' Header
- 112551 (4) - Missing Content Security Policy
- 98063 (2) - Cookie Without HttpOnly Flag Detected
- 115540 (2) - Cookie Without SameSite Flag Detected
- 112553 (1) - Missing 'Cache-Control' Header
- 98526 (5) - Missing Permissions Policy
- 98527 (5) - Missing Referrer Policy
- 98618 (5) - HTTP Header Information Disclosure
- 98050 (3) - Interesting Response
- 113897 (3) - HTML Comments Detected
- 114466 (3) - Path Relative Stylesheet Import
- 98000 (1) - Scan Information
- 98009 (1) - Web Application Sitemap
- 98019 (1) - Network Timeout Encountered
- 98061 (1) - Cookies Collected
- 98136 (1) - Target Information
- 98138 (1) - Screenshot
- 98154 (1) - External URLs
- 98772 (1) - Fetch/XHR Detected
- 112613 (1) - Allowed HTTP Versions
- 112616 (1) - API Detected
- 112723 (1) - Security.txt File Not Detected
- 113393 (1) - Performance Telemetry
- 113837 (1) - PostMessage Wildcard Target Origin Detected
- 172036 (1) - Web Application Scanner

Vulnerabilities by Plugin

[Collapse All](#) | [Expand All](#)

112543 (1) - HTTPS Not Detected

-

Synopsis

HTTPS Not Detected

Description

HTTPS is a protocol that protects the integrity and confidentiality of data between client and server. HTTPS is highly recommended to protect connections to website regardless of its content.

See Also

https://www.owasp.org/index.php/Transport_Layer_Protection_Cheat_Sheet

Solution

Enable HTTPS following best practices.

Risk Factor

High

CVSS v4.0 Base Score

7.6 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:P/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N)

CVSS v3.0 Base Score

7.4 (CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)

CVSS v2.0 Base Score

7.1 (CVSS2#AV:N/AC:H/Au:N/C:C/I:C/A:N)

References

XREF	CWE:319
XREF	WASC:Insufficient Transport Layer Protection
XREF	HIPAA:164.312(a)
XREF	HIPAA:164.312(e)
XREF	CAPEC:102
XREF	CAPEC:117
XREF	CAPEC:383
XREF	CAPEC:477
XREF	CAPEC:65
XREF	DISA_STIG:APSC-DV-000170
XREF	OWASP:2010-A9
XREF	OWASP:2013-A6
XREF	OWASP:2017-A3
XREF	OWASP:2021-A2
XREF	OWASP:2025-A4
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	OWASP_ASVS:4.0.2-9.1.1
XREF	PCI_DSS:3.2-6.5.4
XREF	ISO:27001-A.10.1.1
XREF	ISO:27001-A.14.1.2
XREF	ISO:27001-A.14.1.3
XREF	ISO:27001-A.18.1.5
XREF	NIST:sp800_53-SC-13

Plugin Information

Published: 2019/02/05, Modified: 2024/03/13

Instances

<http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant> (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

OUTPUT

The scanner was unable to detect HTTPS when accessing <https://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant>

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant
```

REQUEST HEADERS

```
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

98060 (5) - Missing 'X-Frame-Options' Header -

Synopsis

Missing 'X-Frame-Options' Header

Description

Clickjacking (User Interface redress attack, UI redress attack, UI redressing) is a malicious technique of tricking a Web user into clicking on something different from what the user perceives they are clicking on, thus potentially revealing confidential information or taking control of their computer while clicking on seemingly innocuous web pages.

The server didn't return an `X-Frame-Options` header which means that this website could be at risk of a clickjacking attack.

The `X-Frame-Options` HTTP response header can be used to indicate whether or not a browser should be allowed to render a page inside a frame or iframe. Sites can use this to avoid clickjacking attacks, by ensuring that their content is not embedded into other sites.

See Also

- <https://developer.mozilla.org/en-US/docs/Web/HTTP/X-Frame-Options>
- <http://tools.ietf.org/html/rfc7034>
- <https://www.owasp.org/index.php/Clickjacking>

Solution

Configure your web server to include an `X-Frame-Options` header.

Risk Factor

Low

CVSS v4.0 Base Score

2.1 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:A/VC:N/VI:L/VA:N/SC:L/SI:L/SA:N)

CVSS v3.0 Base Score

3.1 (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:N/I:L/A:N)

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:N/I:P/A:N)

References

XREF	CWE:1021
XREF	CWE:346
XREF	WASC:Application Misconfiguration
XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)
XREF	CAPEC:103
XREF	CAPEC:111
XREF	CAPEC:141
XREF	CAPEC:142
XREF	CAPEC:160
XREF	CAPEC:181
XREF	CAPEC:21
XREF	CAPEC:222
XREF	CAPEC:384
XREF	CAPEC:385

XREF	CAPEC:386
XREF	CAPEC:387
XREF	CAPEC:388
XREF	CAPEC:504
XREF	CAPEC:506
XREF	CAPEC:510
XREF	CAPEC:59
XREF	CAPEC:60
XREF	CAPEC:654
XREF	CAPEC:75
XREF	CAPEC:76
XREF	CAPEC:89
XREF	DISA_STIG:APSC-DV-002560
XREF	OWASP:2010-A6
XREF	OWASP:2013-A5
XREF	OWASP:2017-A6
XREF	OWASP:2021-A4
XREF	OWASP:2021-A7
XREF	OWASP:2025-A6
XREF	OWASP:2025-A7
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	OWASP_ASVS:4.0.2-14.4.3
XREF	OWASP_ASVS:4.0.2-14.4.7
XREF	PCI_DSS:3.2-6.5
XREF	PCI_DSS:3.2-6.5.8
XREF	ISO:27001-A.10.1
XREF	ISO:27001-A.14.2.5
XREF	NIST:sp800_53-CM-6b
XREF	NIST:sp800_53-SI-10(5)

Plugin Information

Published: 2017/03/31, Modified: 2024/03/25

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health

OUTPUT

Page http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health has no X-Frame-Options header defined

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant/_stcore/health

REQUEST HEADERS

Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*

RESPONSE HEADERS

HTTP/1.1 404 Not Found
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Content-Length: 818
Vary: Accept-Encoding
Content-Encoding: gzip

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/_stcore/health
```

OUTPUT

```
Page http://ai.rcilab.in:5002/_stcore/health has no X-Frame-Options header defined
```

REQUEST MADE

```
GET /_stcore/health
```

REQUEST HEADERS

```
Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Cache-Control: no-cache
Etag: "7a85f4764bbd6daf1c3545efbbf0f279a6dc0beb"
Content-Length: 2
Vary: Accept-Encoding
Set-Cookie: _streamlit_xsrft=2|4850a24d|fb61413ab21607ece7b64330e5047837|1787025861; Path=/
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/_stcore/host-config
```

OUTPUT

```
Page http://ai.rcilab.in:5002/_stcore/host-config has no X-Frame-Options header defined
```

REQUEST MADE

```
GET /_stcore/host-config
```

REQUEST HEADERS

```
Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: application/json; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Cache-Control: no-cache
Etag: "20dcdd871138f403f521aaa2040dbc2f435c0eb7"
Content-Length: 682
Vary: Accept-Encoding
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

OUTPUT

```
Page http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant has no X-Frame-Options header defined
```

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant
```

REQUEST HEADERS

```
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 04:04:04 GMT
Accept-Ranges: bytes
Etag:
"b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfd23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked
```

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
```

URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/was_404_check
```

OUTPUT

```
Page http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/was_404_check has no X-Frame-Options header defined
```

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant/was_404_check
```

REQUEST HEADERS

```
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 05:10:57 GMT
Accept-Ranges: bytes
Etag:
"b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfd23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked
```

Synopsis

Missing 'X-Content-Type-Options' Header

Description

The HTTP 'X-Content-Type-Options' response header prevents the browser from MIME-sniffing a response away from the declared content-type.

The server did not return a correct 'X-Content-Type-Options' header, which means that this website could be at risk of a Cross-Site Scripting (XSS) attack.

See Also

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>
https://www.owasp.org/index.php/OWASP_Secure-Headers_Project#xcto

Solution

Configure your web server to include an 'X-Content-Type-Options' header with a value of 'nosniff'.

Risk Factor

Low

CVSS v4.0 Base Score

2.1 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:A/VC:L/VI:N/VA:N/SC:L/SI:L/SA:N)

CVSS v3.0 Base Score

3.1 (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

References

XREF	CWE:693
XREF	WASC:Application Misconfiguration
XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)
XREF	CAPEC:1
XREF	CAPEC:107
XREF	CAPEC:127
XREF	CAPEC:17
XREF	CAPEC:20
XREF	CAPEC:22
XREF	CAPEC:237
XREF	CAPEC:36
XREF	CAPEC:477
XREF	CAPEC:480
XREF	CAPEC:51
XREF	CAPEC:57
XREF	CAPEC:59
XREF	CAPEC:65
XREF	CAPEC:74
XREF	CAPEC:87
XREF	OWASP:2010-A6
XREF	OWASP:2013-A5
XREF	OWASP:2017-A6
XREF	OWASP:2025-A6
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	PCI_DSS:3.2-2.2
XREF	ISO:27001-A.14.2.5
XREF	NIST:sp800_53-CM-6b

Plugin Information

Published: 2018/11/28, Modified: 2024/03/25

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/_stcore/host-config

OUTPUT

The scanner detected the lack of a correct X-Content-Type-Options header configuration in the target application response

REQUEST MADE

GET /_stcore/host-config

REQUEST HEADERS

Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*

RESPONSE HEADERS

HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: application/json; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Cache-Control: no-cache
Etag: "20dcdd871138f403f521aaa2040dbc2f435c0eb7"
Content-Length: 682
Vary: Accept-Encoding

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/_stcore/health

OUTPUT

The scanner detected the lack of a correct X-Content-Type-Options header configuration in the target application response

REQUEST MADE

GET /_stcore/health

REQUEST HEADERS

Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*

RESPONSE HEADERS

HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Cache-Control: no-cache
Etag: "7a85f4764bbd6daf1c3545efbbf0f279a6dc0beb"
Content-Length: 2
Vary: Accept-Encoding
Set-Cookie: _streamlit_xsrf=2|4850a24d|fb61413ab21607ece7b64330e5047837|1787025861; Path=/

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)

URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health

OUTPUT

The scanner detected the lack of a correct X-Content-Type-Options header configuration in the target application response

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant/_stcore/health

REQUEST HEADERS

Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*

RESPONSE HEADERS

HTTP/1.1 404 Not Found
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Content-Length: 818
Vary: Accept-Encoding
Content-Encoding: gzip

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)

URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

OUTPUT

The scanner detected the lack of a correct X-Content-Type-Options header configuration in the target application response

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant

REQUEST HEADERS

Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9

RESPONSE HEADERS

HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 04:04:04 GMT
Accept-Ranges: bytes
Etag: "b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfdf23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)

URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/was_404_check

OUTPUT

The scanner detected the lack of a correct X-Content-Type-Options header configuration in the target application response

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant/was_404_check

REQUEST HEADERS

Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9

RESPONSE HEADERS

HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 05:10:57 GMT
Accept-Ranges: bytes
Etag: "b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfdd23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked

112551 (4) - Missing Content Security Policy -

Synopsis

Missing Content Security Policy

Description

Content Security Policy (CSP) is a web security standard that helps to mitigate attacks like cross-site scripting (XSS), clickjacking or mixed content issues. CSP provides mechanisms to websites to restrict content that browsers will be allowed to load.

No CSP header has been detected on this host. This URL is flagged as a specific example.

See Also

- <https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP>
- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>
- <https://developers.google.com/web/fundamentals/security/csp/>
- <https://content-security-policy.com/>
- <https://csp-evaluator.withgoogle.com/>

Solution

Configure Content Security Policy on your website by adding 'Content-Security-Policy' HTTP header or meta tag http-equiv='Content-Security-Policy'.

Risk Factor

Low

CVSS v4.0 Base Score

2.1 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N)

CVSS v3.0 Base Score

3.1 (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

References

XREF	CWE:1021
XREF	WASC:Application Misconfiguration
XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)
XREF	CAPEC:103
XREF	CAPEC:181
XREF	CAPEC:222
XREF	CAPEC:504
XREF	CAPEC:506
XREF	CAPEC:654
XREF	DISA_STIG:APSC-DV-002560
XREF	OWASP:2010-A6
XREF	OWASP:2013-A5
XREF	OWASP:2017-A6
XREF	OWASP:2021-A4
XREF	OWASP:2025-A6
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	OWASP_ASVS:4.0.2-14.4.3
XREF	PCI_DSS:3.2-6.5
XREF	ISO:27001-A.14.2.5
XREF	NIST:sp800_53-CM-6b

Plugin Information

Published: 2019/02/14, Modified: 2024/03/25

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health
```

OUTPUT

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health has no Content Security Policy defined.
```

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant/_stcore/health
```

REQUEST HEADERS

```
Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
```

RESPONSE HEADERS

```
HTTP/1.1 404 Not Found
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Content-Length: 818
Vary: Accept-Encoding
Content-Encoding: gzip
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/_stcore/health
```

OUTPUT

```
http://ai.rcilab.in:5002/_stcore/health has no Content Security Policy defined.
```

REQUEST MADE

```
GET /_stcore/health
```

REQUEST HEADERS

```
Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Cache-Control: no-cache
Etag: "7a85f4764bbd6daf1c3545efbbf0f279a6dc0beb"
Content-Length: 2
Vary: Accept-Encoding
Set-Cookie: _streamlit_xsrft=2|4850a24d|fb61413ab21607ece7b64330e5047837|1787025861; Path=/
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

OUTPUT

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant has no Content Security Policy defined.
```

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant
```

REQUEST HEADERS

```
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 04:04:04 GMT
Accept-Ranges: bytes
Etag: "b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfdd23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)

URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/was_404_check
```

OUTPUT

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/was_404_check has no Content Security Policy defined.
```

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant/was_404_check
```

REQUEST HEADERS

```
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 05:10:57 GMT
Accept-Ranges: bytes
Etag:
"b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfdf23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked
```

98063 (2) - Cookie Without HttpOnly Flag Detected

Synopsis

Cookie Without HttpOnly Flag Detected

Description

The HttpOnly flag assists in the prevention of client side-scripts (such as JavaScript) from accessing and using the cookie.

This can help prevent XSS attacks from targeting the cookies holding the client's session token (setting the HttpOnly flag does not prevent, nor safeguard against XSS vulnerabilities themselves).

See Also

<https://www.owasp.org/index.php/HttpOnly>

Solution

The initial step to remedy this would be to determine whether any client-side scripts (such as JavaScript) need to access the cookie and if not, set the HttpOnly flag. It should be noted that some older browsers are not compatible with the HttpOnly flag; therefore, setting this flag will not protect those clients against this form of attack.

Risk Factor

Low

CVSS v4.0 Base Score

2.1 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N)

CVSS v3.0 Base Score

3.1 (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

References

XREF	CWE:1004
XREF	WASC:Application Misconfiguration
XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)
XREF	DISA_STIG:APSC-DV-002210
XREF	OWASP:2010-A9
XREF	OWASP:2013-A6
XREF	OWASP:2017-A3
XREF	OWASP:2021-A5
XREF	OWASP:2025-A2
XREF	OWASP_ASVS:4.0.2-3.4.2
XREF	PCI_DSS:3.2-6.5.10
XREF	ISO:27001-A.14.2.5
XREF	NIST:sp800_53-CM-6b

Plugin Information

Published: 2017/03/31, Modified: 2026/01/28

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

INPUT TYPE

cookie

INPUT NAME

_streamlit_xsrf

PROOF

Set-Cookie : _streamlit_xsrf=2|cae22105|38bea7754941e94b2a0ee46b81e94a72|1787025845; Path=/

OUTPUT

The scanner detected a cookie named '_streamlit_xsrf' set through a 'Set-Cookie' that does not set the HttpOnly flag.

If the cookie is set to handle sensitive information (for example session-based information), it should be set via the HTTP method.

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant

REQUEST HEADERS

Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9

RESPONSE HEADERS

HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 04:04:04 GMT
Accept-Ranges: bytes
Etag:

```
"b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfd23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

INPUT TYPE

cookie

INPUT NAME

ajs_anonymous_id

PROOF

ajs_anonymous_id=b5fc66df-5b95-420e-a5d8-098bec7b962e; Path=/; Expires=2027-08-18 09:31:55 +0000

OUTPUT

The scanner detected a cookie named 'ajs_anonymous_id' set with JavaScript which prevents the HTTPOnly attribute from being used.
If the cookie is set to handle sensitive information (for example session-based information), it should be set via the HTTP method.

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant

REQUEST HEADERS

Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9

RESPONSE HEADERS

HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 04:04:04 GMT
Accept-Ranges: bytes
Etag:
"b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfd23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked

115540 (2) - Cookie Without SameSite Flag Detected

-

Synopsis

Cookie Without SameSite Flag Detected

Description

SameSite is an attribute which can be set on a cookie to instruct the web browser if this cookie can be sent along with cross-site requests to help prevent Cross-Site Request Forgery (CSRF) attacks.

The attribute has three possible values :

- Strict : the cookie will only be sent in a first-party context, thus preventing cross-site requests initiated from third-party websites to include it.
- Lax : the cookie is allowed to be sent in GET cross-site requests initiated by the top-level navigation from third-party websites. For example, following an hypertext link from the external website will make the request include the cookie.
- None : the cookie is explicitly set to be sent by the browser in any context.

The scanner identified the lack of SameSite attribute on cookies set by the application or a misconfiguration.

See Also

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Set-Cookie/SameSite>
https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html#samesite-cookie-attribute
<https://web.dev/samesite-cookies-explained>
<https://blog.chromium.org/2019/10/developers-get-ready-for-new.html>

Solution

Web browsers default behavior may differ when processing cookies in a cross-site context, making the final decision to send the cookie in this context unpredictable. The SameSite attribute should be set in every cookie to enforce the expected result by developers. When using the 'None' attribute value, ensure that the cookie is also set with the 'Secure' flag.

Risk Factor

Low

CVSS v4.0 Base Score

2.1 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N)

CVSS v3.0 Base Score

3.1 (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

References

XREF	CWE:352
XREF	WASC:Cross-Site Request Forgery
XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)
XREF	CAPEC:111
XREF	CAPEC:462
XREF	CAPEC:467
XREF	CAPEC:62
XREF	DISA_STIG:APSC-DV-002500
XREF	OWASP:2010-A5
XREF	OWASP:2013-A8
XREF	OWASP:2021-A1
XREF	OWASP:2025-A1
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	OWASP_ASVS:4.0.2-4.2.2
XREF	PCI_DSS:3.2-6.5.9
XREF	ISO:27001-A.12.6.1
XREF	ISO:27001-A.14.2.5
XREF	NIST:sp800_53-SI-10(5)

Plugin Information

Published: 2018/12/14, Modified: 2026/01/28

Instances

<http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant> (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

INPUT TYPE

```
cookie
```

INPUT NAME

```
_streamlit_xsrf
```

PROOF

```
Set-Cookie : _streamlit_xsrf=2|cae22105|38bea7754941e94b2a0ee46b81e94a72|1787025845; Path=/
```

OUTPUT

```
The scanner detected a cookie named '_streamlit_xsrf' set through a 'Set-Cookie' header which does not have the 'SameSite' attribute set.
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

INPUT TYPE

```
cookie
```

INPUT NAME

```
ajs_anonymous_id
```

PROOF

```
ajs_anonymous_id=b5fc66df-5b95-420e-a5d8-098bec7b962e; Path=/; Expires=2027-08-18 09:31:55 +0000
```

OUTPUT

```
The scanner detected a cookie named 'ajs_anonymous_id' set with JavaScript which does not have the 'SameSite' attribute set.
```

112553 (1) - Missing 'Cache-Control' Header

Synopsis

Missing 'Cache-Control' Header

Description

The HTTP 'Cache-Control' header is used to specify directives for caching mechanisms.

The server did not return or returned an invalid 'Cache-Control' header which means page containing sensitive information (password, credit card, personal data, social security number, etc) could be stored on client side disk and then be exposed to unauthorised persons. This URL is flagged as a specific example.

See Also

[https://www.owasp.org/index.php/Testing_for_Browser_cache_weakness_\(OTG-AUTHN-006\)](https://www.owasp.org/index.php/Testing_for_Browser_cache_weakness_(OTG-AUTHN-006))
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cache-Control>

Solution

Configure your web server to include a 'Cache-Control' header with appropriate directives. If page contains sensitive information 'Cache-Control' value should be 'no-store' and 'Pragma' header value should be 'no-cache'.

Risk Factor

Low

CVSS v4.0 Base Score

2.1 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N)

CVSS v3.0 Base Score

3.7 (CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

References

XREF	CWE:525
XREF	WASC:Application Misconfiguration
XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)
XREF	CAPEC:37
XREF	DISA_STIG:APSC-DV-002480
XREF	OWASP:2010-A6
XREF	OWASP:2013-A5
XREF	OWASP:2017-A6
XREF	OWASP:2021-A4
XREF	OWASP:2025-A6
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	OWASP_ASVS:4.0.2-8.2.1
XREF	PCI_DSS:3.2-2.2
XREF	ISO:27001-A.14.2.5
XREF	NIST:sp800_53-CM-6b

Plugin Information

Published: 2019/02/15, Modified: 2024/03/25

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health
```

OUTPUT

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health has no Cache Control header defined.
```

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant/_stcore/health
```

REQUEST HEADERS

```
Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
```

RESPONSE HEADERS

```
HTTP/1.1 404 Not Found
Server: TornadoServer/6.5.1
```

```
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Content-Length: 818
Vary: Accept-Encoding
Content-Encoding: gzip
```

98526 (5) - Missing Permissions Policy

Synopsis

Missing Permissions Policy

Description

Permissions Policy provides mechanisms to websites to restrict the use of browser features in its own frame and in iframes that it embeds.

See Also

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Feature-Policy>
<https://scotthelme.co.uk/goodbye-feature-policy-and-hello-permissions-policy/>

Solution

Configure Permissions Policy on your website by adding 'Permissions-Policy' HTTP header.

Risk Factor

None

Plugin Information

Published: 2019/03/27, Modified: 2024/03/25

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health
```

OUTPUT

```
No Permissions-Policy headers were found on http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health
```

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant/_stcore/health
```

REQUEST HEADERS

```
Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
```

RESPONSE HEADERS

```
HTTP/1.1 404 Not Found
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Content-Length: 818
Vary: Accept-Encoding
Content-Encoding: gzip
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/_stcore/health
```

OUTPUT

No Permissions-Policy headers were found on http://ai.rcilab.in:5002/_stcore/health

REQUEST MADE

GET /_stcore/health

REQUEST HEADERS

Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*

RESPONSE HEADERS

HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Cache-Control: no-cache
Etag: "7a85f4764bbd6daf1c3545efbbf0f279a6dc0beb"
Content-Length: 2
Vary: Accept-Encoding
Set-Cookie: _streamlit_xsrftoken=2|4850a24d|fb61413ab21607ece7b64330e5047837|1787025861; Path=

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/_stcore/host-config

OUTPUT

No Permissions-Policy headers were found on http://ai.rcilab.in:5002/_stcore/host-config

REQUEST MADE

GET /_stcore/host-config

REQUEST HEADERS

Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*

RESPONSE HEADERS

HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: application/json; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Cache-Control: no-cache
Etag: "20dcdd871138f403f521aaa2040dbc2f435c0eb7"
Content-Length: 682
Vary: Accept-Encoding

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

OUTPUT

No Permissions-Policy headers were found on http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant

REQUEST HEADERS

Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9

RESPONSE HEADERS

HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 04:04:04 GMT
Accept-Ranges: bytes
Etag: "b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfdd23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/was_404_check

OUTPUT

No Permissions-Policy headers were found on http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/was_404_check

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant/was_404_check

REQUEST HEADERS

Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9

RESPONSE HEADERS

HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 05:10:57 GMT
Accept-Ranges: bytes
Etag: "b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfdd23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked

Description

Referrer Policy provides mechanisms to websites to restrict referrer information (sent in the referer header) that browsers will be allowed to add.

No Referrer Policy header or metatag configuration has been detected.

See Also

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy>

Solution

Configure Referrer Policy on your website by adding 'Referrer-Policy' HTTP header or meta tag referrer in HTML.

Risk Factor

None

Plugin Information

Published: 2019/04/02, Modified: 2024/03/25

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health

OUTPUT

No Referrer-Policy headers or body meta tags were found on http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant/_stcore/health

REQUEST HEADERS

Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*

RESPONSE HEADERS

HTTP/1.1 404 Not Found
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Content-Length: 818
Vary: Accept-Encoding
Content-Encoding: gzip

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/_stcore/health

OUTPUT

No Referrer-Policy headers or body meta tags were found on http://ai.rcilab.in:5002/_stcore/health

REQUEST MADE

```
GET /_stcore/health
```

REQUEST HEADERS

```
Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Cache-Control: no-cache
Etag: "7a85f4764bbd6daf1c3545efbbf0f279a6dc0beb"
Content-Length: 2
Vary: Accept-Encoding
Set-Cookie: _streamlit_xsrft=2|4850a24d|fb61413ab21607ece7b64330e5047837|1787025861; Path=/
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/_stcore/host-config
```

OUTPUT

No Referrer-Policy headers or body meta tags were found on http://ai.rcilab.in:5002/_stcore/host-config

REQUEST MADE

```
GET /_stcore/host-config
```

REQUEST HEADERS

```
Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: application/json; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Cache-Control: no-cache
Etag: "20dcdd871138f403f521aaa2040dbc2f435c0eb7"
Content-Length: 682
Vary: Accept-Encoding
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

OUTPUT

No Referrer-Policy headers or body meta tags were found on http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant
```

REQUEST HEADERS

```
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 04:04:04 GMT
Accept-Ranges: bytes
Etag:
"b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfdf23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/was_404_check
```

OUTPUT

```
No Referrer-Policy headers or body meta tags were found on
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/was_404_check
```

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant/was_404_check
```

REQUEST HEADERS

```
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 05:10:57 GMT
Accept-Ranges: bytes
Etag:
"b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfdf23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked
```

98618 (5) - HTTP Header Information Disclosure

Synopsis

HTTP Header Information Disclosure

Description

The HTTP headers sent by the remote web server disclose information that can aid an attacker, such as the server version and technologies used by the web server.

See Also

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers>
<http://projects.webappsec.org/w/page/13246925/Fingerprinting>

Solution

Modify the HTTP headers of the web server to not disclose detailed information about the underlying web server.

Risk Factor

None

Plugin Information

Published: 2019/06/12, Modified: 2024/03/25

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant(tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health

OUTPUT

The following header information disclosures have been detected on http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health:

- Server: TornadoServer/6.5.1

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant/_stcore/health

REQUEST HEADERS

Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*

RESPONSE HEADERS

HTTP/1.1 404 Not Found
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Content-Length: 818
Vary: Accept-Encoding
Content-Encoding: gzip

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant(tcp/5002)
URL

http://ai.rcilab.in:5002/_stcore/health

OUTPUT

The following header information disclosures have been detected on http://ai.rcilab.in:5002/_stcore/health:

- Server: TornadoServer/6.5.1

REQUEST MADE

```
GET /_stcore/health
```

REQUEST HEADERS

```
Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Cache-Control: no-cache
Etag: "7a85f4764bbd6daf1c3545efbbf0f279a6dc0beb"
Content-Length: 2
Vary: Accept-Encoding
Set-Cookie: _streamlit_xsrf=2|4850a24d|fb61413ab21607ece7b64330e5047837|1787025861; Path=/
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/_stcore/host-config
```

OUTPUT

```
The following header information disclosures have been detected on http://ai.rcilab.in:5002/_stcore/host-config:

- Server: TornadoServer/6.5.1
```

REQUEST MADE

```
GET /_stcore/host-config
```

REQUEST HEADERS

```
Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: application/json; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Cache-Control: no-cache
Etag: "20dcdd871138f403f521aaa2040dbc2f435c0eb7"
Content-Length: 682
Vary: Accept-Encoding
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/was_404_check
```

OUTPUT

```
The following header information disclosures have been detected on
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/was_404_check:

- Server: TornadoServer/6.5.1
```

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant/was_404_check
```

REQUEST HEADERS

```
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 05:10:57 GMT
Accept-Ranges: bytes
Etag:
"b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfd23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

OUTPUT

```
The following header information disclosures have been detected on
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant:

- Server: TornadoServer/6.5.1
```

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant
```

REQUEST HEADERS

```
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 04:04:04 GMT
Accept-Ranges: bytes
Etag:
"b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfd23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked
```

98050 (3) - Interesting Response

Synopsis

Interesting Response

Description

The scanner identified some responses with a status code other than the usual 200 (OK), 301 (Moved Permanently), 302 (Found) and 404 (Not Found) codes. These codes can provide useful insights into the behavior of the web application and identify any unexpected responses to be addressed.

See Also

<http://www.w3.org/Protocols/rfc2616/rfc2616-sec10.html>
https://en.wikipedia.org/wiki/List_of_HTTP_status_codes

Risk Factor

None

Plugin Information

Published: 2017/03/31, Modified: 2021/06/14

Instances

<http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant> (tcp/5002)
URL

```
http://ai.rcilab.in:5002/rest/V1/guest-carts/78/estimate-shipping-methods
```

PROOF

```
HTTP/1.1 403 Forbidden
```

OUTPUT

A response has been received with a response code '403' which may require further investigation to verify if this response is due to an abnormal behavior of the target.

The response has been triggered by an HTTP POST request made on the URL 'http://ai.rcilab.in:5002/rest/V1/guest-carts/78/estimate-shipping-methods'.

REQUEST MADE

```
POST /rest/V1/guest-carts/78/estimate-shipping-methods HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:5002
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Content-Type: application/json
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
Cookie: ajs_anonymous_id=b5fc66df-5b95-420e-a5d8-098bec7b962e;
_streamlit_xsrf=2|6efa902b|794137a930eb9251cdc499bb0b90a06b|1787025815
Content-Length: 204

{"address":{"totalsCollector":{"collectorList":{"totalCollector":{"sourceData":{"data":{"https://gys6igyx4rfum2vf2jzwnosruod6fbms56h5f6u2sf4igkcjbqx.was.nessus.org","dataIsURL":true,"options":524290}}}}}}}
```

RESPONSE HEADERS

```
HTTP/1.1 403 Forbidden
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 05:08:36 GMT
Content-Length: 69
Vary: Accept-Encoding
```

<http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant> (tcp/5002)

URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/api/content/
```

PROOF

```
HTTP/1.1 400 Bad Request
```

OUTPUT

A response has been received with a response code '400' which may require further investigation to verify if this response is due to an abnormal behavior of the target.

The response has been triggered by an HTTP POST request made on the URL
'http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/api/content/'.

REQUEST MADE

```
POST /Procurement%20Policy%20Related%20Assistant/_stcore/api/content/ HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:5002
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Content-Type: multipart/form-data; boundary=-----aadc326f7ae3eac3
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
Cookie: ajs_anonymous_id=b5fc66df-5b95-420e-a5d8-098bec7b962e;
_streamlit_xsrf=2|241176e7|33aad1657a00749d872f7f77417b46a7|1787025815
Content-Length: 229

-----aadc326f7ae3eac3
Content-Disposition: form-data; name="name"; filename="../../../tmp-wastnb"
Content-Type: text/plain

-----aadc326f7ae3eac3--
```

RESPONSE HEADERS

```
HTTP/1.1 400 Bad Request
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 05:09:10 GMT
Content-Length: 73
Vary: Accept-Encoding
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

PROOF

```
HTTP/1.1 405 Method Not Allowed
```

OUTPUT

A response has been received with a response code '405' which may require further investigation to verify if this response is due to an abnormal behavior of the target.

The response has been triggered by an HTTP TRACE request made on the URL
'http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/'.

REQUEST MADE

TRACE /Procurement%20Policy%20Related%20Assistant HTTP/1.1

REQUEST HEADERS

Host: ai.rcilab.in:5002
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
X-Tenable-Wasscan-Trace: 1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
Cookie: ajs_anonymous_id=b5fc66df-5b95-420e-a5d8-098bec7b962e; _streamlit_xsrf=2|94381e82|8383b900ca291cf837061712f1522ec2|1787025815

RESPONSE HEADERS

HTTP/1.1 405 Method Not Allowed
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 05:07:45 GMT
Content-Length: 87
Vary: Accept-Encoding

113897 (3) - HTML Comments Detected

Synopsis

HTML Comments Detected

Description

HTML comments are often used by developers to include information related to the application inline, which are ignored by a clients browser during rendering. These comments may include sensitive information such as SQL queries, credentials or internal IP for example.

See Also

https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/05-Review_Webpage_Content_for_Information_Leakage

Solution

Review the HTML comments identified on the page for any information leakage, and remove any sensitive information identified.

Risk Factor

None

Plugin Information

Published: 2023/06/09, Modified: 2024/11/08

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health

OUTPUT

2 HTML comments have been detected in the application HTTP response. Please see the attachment for further details.

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant/_stcore/health

REQUEST HEADERS

```
Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
```

RESPONSE HEADERS

```
HTTP/1.1 404 Not Found
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Content-Length: 818
Vary: Accept-Encoding
Content-Encoding: gzip
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

OUTPUT

1 HTML comments have been detected in the application HTTP response. Please see the attachment for further details.

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant
```

REQUEST HEADERS

```
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 04:04:04 GMT
Accept-Ranges: bytes
Etag:
"b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfdf23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/was_404_check
```

OUTPUT

1 HTML comments have been detected in the application HTTP response. Please see the attachment for further details.

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant/was_404_check
```

REQUEST HEADERS

Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9

RESPONSE HEADERS

HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 05:10:57 GMT
Accept-Ranges: bytes
Etag: "b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfd23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked

114466 (3) - Path Relative Stylesheet Import

Synopsis

Path Relative Stylesheet Import

Description

A Path Relative Style Sheet Import occurs when the application imports a style sheet via a relative URL and uses user input in the file name. This vulnerability mainly affects older browsers such as Internet Explorer and allows an attacker to exploit the way the browser handles stylesheet imports in order to perform CSS Injection.

See Also

<https://cspelite.com/csp290/>

Solution

It is preferable not to use path-related URLs in stylesheet imports, and also to use the 'X-Content-Type-Options: nosnif' and 'X-Frame-Options: deny' headers.

Risk Factor

None

Plugin Information

Published: 2024/10/30, Modified: 2024/11/08

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/_stcore/health

PROOF

The following value is extracted from a <link> tag that imports a style sheet with a 'href' that does not begin with a / :
* ./static/css/index.CJVRHjQZ.css

OUTPUT

The scanner was able to detect a Path Relative Stylesheet Import.

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant/_stcore/health

REQUEST HEADERS

```
Referer: http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
```

RESPONSE HEADERS

```
HTTP/1.1 404 Not Found
Server: TornadoServer/6.5.1
Content-Type: text/html; charset=UTF-8
Date: Tue, 18 Aug 2026 04:04:21 GMT
Content-Length: 818
Vary: Accept-Encoding
Content-Encoding: gzip
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

PROOF

```
The following value is extracted from a <link> tag that imports a style sheet with a 'href' that does not begin with a / :
* ./static/css/index.CJVRHjQZ.css
```

OUTPUT

```
The scanner was able to detect a Path Relative Stylesheet Import.
```

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant
```

REQUEST HEADERS

```
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 04:04:04 GMT
Accept-Ranges: bytes
Etag:
"b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdf23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked
```

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant/was_404_check
```

PROOF

```
The following value is extracted from a <link> tag that imports a style sheet with a 'href' that does not begin with a / :
* ./static/css/index.CJVRHjQZ.css
```

OUTPUT

The scanner was able to detect a Path Relative Stylesheet Import.

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant/was_404_check

REQUEST HEADERS

Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9

RESPONSE HEADERS

HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 05:10:57 GMT
Accept-Ranges: bytes
Etag: "b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfdf23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked

98000 (1) - Scan Information -

Synopsis

Scan Information

Description

Provides scan information and statistics of plugins run.

Risk Factor

None

Plugin Information

Published: 2017/03/31, Modified: 2026/04/30

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

OUTPUT

Engine Version 2.111.8-2273
Plugins Version 202608110549
Scan ID 78b815f3-ada1-4324-a0ec-c2b9f852d23b
Scanner Public IP N/A

Start Time 2026-08-18 09:31:50 +0000
Duration 01:46:52

Requests 8327
Crawler Requests 137
Requests/s 23.1691
Mean Response Time 0.1039s

Bandwidth Usage
- Data to Target 4.76 MB
- Data from Target 12.5 MB

Timeouts Encountered

Network Timeouts 1

Browser Timeouts 0

Browser Respawns 0

HTTP Protocols Detected

- HTTP
- HTTPS

Authentication Identified

- None

Plugins

- 1052 have been included per scan policy
- 705 have been started based on target information collected

List of plugins is available in 'plugins.csv' attachment.

Settings used to conduct this scan are available in 'configuration.csv' attachment.

98009 (1) - Web Application Sitemap

Synopsis

Web Application Sitemap

Description

Publishes the sitemap of the web application as seen by the scan.

The list of all URLs that have been detected during the scan are available as an attachment. For each URL in the sitemap, the following information is provided:

- The first time the URL is detected - The logic used to detect the URL. This information may be found by: crawling rendering the page by a specific plugin - The parent URL requested to detect the URL - If the URL has been requested at least once, information about the response - Whether or not the URL has been queued for audit - If the URL has not been queued for audit, the reason why the URL does not need an audit - Whether or not the URL has been effectively audited - If the URL has not been effectively audited, the reason that the scanner was unable to audit the URL

Reasons for not adding a URL to the audit queue are as follows:

- not_in_domain: The domain of the URL does not match main target URL - scope_configuration: The URL does not match scope include list scan settings - directory_depth: The number of directories in the URL path exceeds the scan configuration setting - exclude_file_extension: The URL file extension matched one entry of the file extension blacklist setting - exclude_path_patterns: The URL matched one entry of the URL exclusion blacklist setting - redundant_path: The number of URLs to be audited with the same path and query string parameters has been reached - request_redirect_limit: The number of HTTP redirects allowed per scan configuration setting has been reached - queue_full: The number of URLs to audit has been reached

If a scan fails to audit a URL that has been queued for audit, reasons for the failure are as follows:

- timeout: The request timed out when trying to retrieve URL contents - filesize_exceeded: URL response exceeded file size limit defined in the scan configuration - scan_timelimit_reached: The URL couldn't be audited before the scan time limit - user_abort: The user stopped the scan before the URL could be audited

Risk Factor

None

Plugin Information

Published: 2017/03/31, Modified: 2023/11/17

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

OUTPUT

The scan has discovered 34 distinct URLs.

The following is a breakdown of which URLs were audited:

- 5 effectively audited
- 23 not queued due to file extension exclusions
- 3 not queued due to the URL containing a fragment which is a feature of browsers and not included in HTTP requests. The page being referred to by the fragment shall still be audited by the scanner.
- 2 not queued due to the URL not being in the target domain

For URLs we received responses for, here is a distribution of the content type headers:

- 14 application/javascript
- 1 application/json; charset=utf-8
- 1 image/png
- 1 text/css
- 6 text/html
- 3 text/html; charset=utf-8

Response times ranged between 0.14365s and 0.14365s.

You can access the complete list of URLs with the information collected by the scan as an attachment to this plugin.

98019 (1) - Network Timeout Encountered

Synopsis

Network Timeout Encountered

Description

Provides a report of network timeouts encountered during the scan, showing URLs and the number of timeouts for each URL.

Note that assessment will stop on any URLs in timeout state, and timeouts may increase significantly the overall duration of the scan.

Solution

Check your web application logs and verify that it is functioning as expected and can handle significant amounts of traffic generated by the scanner. Additionally, the scan policy may be edited to optimize the performance settings.

Risk Factor

None

Plugin Information

Published: 2017/09/25, Modified: 2023/11/17

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

OUTPUT

The scanner encountered 1 network timeout during the scan. See the attachment for more details

98061 (1) - Cookies Collected

Synopsis

Cookies Collected

Description

The scanner collected the cookies returned by the application during the scan. The list includes the following information for each cookie:

- Name: name of the cookie
- Value: value of the cookie
- Domain: hosts to which the cookie will be sent
- Path: URL path which must exist in the requested resource before sending the cookie
- Expires: maximum lifetime of the cookie as an HTTP-date timestamp

- Max-Age: number of seconds until the cookie expires
- HttpOnly: cookie is set to be not accessible via JavaScript, XMLHttpRequest and Request APIs
- Secure: cookie will be sent to the server only when a request is made using HTTPS
- SameSite: cookie will be sent along with cross-site request according the defined policy
- URL: first URL discovered which set the cookie in its response
- Set-Method: method used by the application to set the cookie (Set-Cookie or JavaScript)
- Audited: cookie will be audited by plugins during the scan
- Reason Not Audited: reason given for the cookie not being audited during the scan

See Also

https://en.wikipedia.org/wiki/HTTP_cookie
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies>
<https://tools.ietf.org/html/rfc6265>

Risk Factor

None

Plugin Information

Published: 2020/09/01, Modified: 2023/11/17

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

OUTPUT

The following cookies have been collected during the scan of the target:
- 0 cookie(s) specified via Set-Cookie
- 2 cookie(s) set via JavaScript code
The complete list of the cookies is available in attachment.

98136 (1) - Target Information -

Synopsis

Target Information

Description

Publishes the target information of the starting url as evaluated by the scan.

Risk Factor

None

Plugin Information

Published: 2017/07/27, Modified: 2024/04/26

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

OUTPUT

Access to URL 'http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant' has been confirmed.

Target Information

Domain Name : ai.rcilab.in

IP Address : 172.27.30.222

Response Information

Status Code : 200
Return Code : ok
Return Message: No error
Response Time : 0.005173s
Response Size : 1938 bytes
Content-Type : text/html

REQUEST MADE

GET /Procurement%20Policy%20Related%20Assistant HTTP/1.1

REQUEST HEADERS

Host: ai.rcilab.in:5002
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5

RESPONSE HEADERS

HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 04:03:34 GMT
Accept-Ranges: bytes
Etag: "b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdfdd23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked

98138 (1) - Screenshot

Synopsis

Screenshot

Description

Screenshot of the target web page, see attached image. This screenshot should show you the target page we are launching the scan against. If the image is not of the intended target page, please check the provided url in the scan configuration.

Risk Factor

None

Plugin Information

Published: 2018/01/23, Modified: 2018/02/14

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

OUTPUT

WAS Scanner has taken a screenshot of the page at url 'http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant' with dimensions 1600x1200.

Please see the attachment for the screenshot image.

98154 (1) - External URLs

Synopsis

External URLs

Description

An external URL is an URL for which the Fully Qualified Domain Name (FQDN) is not the same as the web target URL one. The scanner detected the presence of external URLs on the target web application and have listed them based on two types : URLs with a domain name in common with the web target URL and all the other external URLs.

Risk Factor

None

Plugin Information

Published: 2022/11/30, Modified: 2022/12/12

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

OUTPUT

The scanner detected the presence of 1 URLs on the target application:

- 0 URLs which use a hostname related to the target hostname
- 1 URLs which use a third party hostname

The list of the detected URLs is provided in attachment.

98772 (1) - Fetch/XHR Detected

Synopsis

Fetch/XHR Detected

Description

The scan detected that the web application makes requests that appear to be using Fetch or XMLHttpRequests (XHRs) to communicate with a backend API server. Fetches/XHRs allow retrieval of data from an API without triggering a page reload, making them especially useful for Single Page Applications.

See Also

<https://developer.mozilla.org/en-US/docs/Web/API/XMLHttpRequest>

Risk Factor

None

Plugin Information

Published: 2019/11/14, Modified: 2023/11/17

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

OUTPUT

The scan detected 4 unique XMLHttpRequests. Here is the distribution of MIME types used by the detected requests:

- 3 as "text/html"
- 1 as "application/json"

The scan detected 3 unique Fetch Requests. Here is the distribution of MIME types used by the detected requests:

- 2 as "application/pdf"
- 1 with no specified or detected MIME type

112613 (1) - Allowed HTTP Versions

Synopsis

Allowed HTTP Versions

Description

The Hypertext Transfer Protocol (HTTP) is the underlying protocol of the World Wide Web. Since its first release, HTTP has evolved to support modern web usages and currently exists in three versions:

- HTTP/1.0
- HTTP/1.1
- HTTP/2

The scanner identified the supported versions of the HTTP protocol on the target web application.

See Also

https://developer.mozilla.org/en-US/docs/Web/HTTP/Basics_of_HTTP/Evolution_of_HTTP

Risk Factor

None

Plugin Information

Published: 2020/10/13, Modified: 2023/01/17

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

OUTPUT

The scanner detected the following HTTP versions on the target application :

- HTTP/1.1

The list of requests and responses observed is provided in attachment.

112616 (1) - API Detected

Synopsis

API Detected

Description

The scan detected that some XHR requests seem to call an API. The scanner generated an OpenAPI file based on the observed requests and attached it to the plugin output. This OpenAPI file can then be used to run a scan against the API with WAS API Scanning.

Risk Factor

None

Plugin Information

Published: 2020/10/21, Modified: 2020/10/21

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)

URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

OUTPUT

```
API endpoints have been detected for the following host(s):  
- http://ai.rcilab.in:5002  
- https://data.streamlit.io
```

112723 (1) - Security.txt File Not Detected

Synopsis

Security.txt File Not Detected

Description

A Security.txt file has not been detected on the target.

When security risks in web services are discovered by independent security researchers, this file defines the channels to disclose them properly & enables 3rd party researchers to disclose issues securely in a manner defined by the organization.

Organizations should consider creating a security.txt file containing contact and other information in the defined format and place it under the .well-known directory of the server.

See Also

<https://securitytxt.org/>

<https://tools.ietf.org/html/draft-foudil-securitytxt-11>

Risk Factor

None

Plugin Information

Published: 2021/03/17, Modified: 2021/03/17

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)

URL

```
http://ai.rcilab.in:5002/.well-known/security.txt
```

OUTPUT

```
No or a malformed security.txt was found at 'http://ai.rcilab.in:5002/.well-known/security.txt'.
```

REQUEST MADE

```
GET /.well-known/security.txt HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:5002  
Accept-Encoding: gzip, deflate, br  
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36  
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7  
Accept-Language: en-US,en;q=0.5  
Cookie: ajs_anonymous_id=b5fc66df-5b95-420e-a5d8-098bec7b962e; _streamlit_xsrf=2|cae22105|38bea7754941e94b2a0ee46b81e94a72|1787025845
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 04:04:22 GMT
Accept-Ranges: bytes
Etag:
"b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdf23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked
```

113393 (1) - Performance Telemetry

Synopsis

Performance Telemetry

Description

This finding provides information to assist in scan performance tuning.

Risk Factor

None

Plugin Information

Published: 2022/10/17, Modified: 2024/10/03

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant

OUTPUT

```
Three attachments are included in this finding to assist in performance tuning of your scan:
-pages_telemetry.csv: Scan statistics organized by page
-plugins_telemetry.csv: Scan statistics organized by plugin
-time_telemetry.csv: Chronological scan statistics
```

113837 (1) - PostMessage Wildcard Target Origin Detected

Synopsis

PostMessage Wildcard Target Origin Detected

Description

Web applications relying on JavaScript often need to perform cross-origin communication between 'Window' objects such as a page and an embedded iframe or a popup window. The postMessage API allows developers to circumvent the same-origin policy restrictions in order to exchange data between scripts located on different origins.

Depending on the application needs, the messages can be sent to the wildcard origin '*', allowing any other object to read it. However, if the data sent through postMessage() are not intended to be public, an attacker could leverage this issue to capture sensitive data from a target web application.

See Also

<https://developer.mozilla.org/en-US/docs/Web/API/Window/postMessage>
<https://blog.yeswehack.com/yeswerhackers/introduction-postmessage-vulnerabilities/>

Solution

Ensure that the messages sent through the postMessage() API are expected to be read by any third party. If not, you should specify the target origin which should receive the messages.

Risk Factor

None

Plugin Information

Published: 2023/05/05, Modified: 2023/05/05

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
URL

```
http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant
```

OUTPUT

The scanner detected the presence of messages sent to the wildcard origin through postMessage on the target URL. The list of the messages detected is provided in attachment.

REQUEST MADE

```
GET /Procurement%20Policy%20Related%20Assistant
```

REQUEST HEADERS

```
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
Server: TornadoServer/6.5.1
Content-Type: text/html
Date: Tue, 18 Aug 2026 04:04:04 GMT
Accept-Ranges: bytes
Etag:
"b28299c78af59ae99e13f53112c58f01c835a0d914fc821ca570a4d31932b02ed848ee1c2b94babcbdf23a3f032cca67330f50a61e0e524aef4b2087e5e2523"
Last-Modified: Sat, 05 Jul 2025 17:24:52 GMT
Cache-Control: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Transfer-Encoding: chunked
```

172036 (1) - Web Application Scanner

Synopsis

Discovers vulnerabilities in Web applications.

Description

This plugin provides vulnerability detections in Web applications and Web site files.

See Also

<http://www.nessus.org/u?db90e0fd>

Solution

Vulnerabilities resolution depends on WAS results.

Risk Factor

None

Plugin Information

Instances

http://ai.rcilab.in:5002/Procurement%20Policy%20Related%20Assistant (tcp/5002)
OUTPUT

Scan completed. Please see the attachments for more information.